PERFORMANCE WORK STATEMENT (PWS) FOR
INFORMATION SYSTEMS SECURITY ENGINEER (ISSE)
IN SUPPORT FOR NAVAL FACILITIES ENGINEERING SYSTEMS COMMAND (NAVFAC) MARIANAS
COMMAND INFORMATION OFFICE (CIO)

1.0 ORGANIZATION

Naval Facilities Engineering Systems Command Marianas
PSC 455, Box 195
FPO AP 96540-2937

2.0 SCOPE

The scope of this requisition is to provide Information Systems Security Engineer (ISSE) services to the Naval Facilities Engineering Systems Command (NAVFAC) Marianas Command Information Office (CIO), ensuring the confidentiality, integrity, and availability of systems, networks, and data through the planning, analysis, development, implementation, documentation, maintenance, and enhancement of information systems security programs, policies, procedures, and tools.

The Contractor shall be responsible for complying with all applicable Federal Acquisition Regulations (FAR) and the Defense Federal Acquisition Regulation Supplement (DFARS).

Personnel working under the provisions of this contract are considered “Emergency Essential” and/or “Mission Essential”. During emergency conditions or expanded mission conditions personnel under this contract will have unfettered access to all military installations and facilities to perform required maintenance actions.

3.0 TASKS/SERVICES

- RMF Lifecycle Execution
    - The Contractor shall drive the end-to-end Risk Management Framework (RMF) lifecycle (Steps 1-6) in strict accordance with the latest published Department of the Navy (DoN) and NAVFAC Echelon II guidance. This includes rigorously verifying system inventories and artifacts for compliance, completeness, and quality, and ensuring accurate formatting and upload into the Enterprise Mission Assurance Support Service (eMASS).
- Authority to Operate (ATO) Attainment & Maintenance
    - The Contractor shall execute comprehensive ISSE activities to achieve, maintain, and track Authorities to Operate (ATOs) for Facility-Related Control Systems (FRCS). This includes facilitating comprehensive annual security reviews and drafting/submitting Memorandums for Record (MFRs) for system baseline changes during RMF Step 6.
- Policy & Procedure Development
    - The Contractor shall develop, author, and maintain comprehensive security policies, standard operating procedures (SOPs), and implementation plans across all applicable

NIST SP 800-53 security control families. This documentation must be tailored to the FRCS operational environment and ensure strict alignment with DoN and NAVFAC Echelon II cybersecurity directives.

- Vulnerability Management & Compliance Assessments
    - The Contractor shall develop, maintain, and execute a comprehensive Vulnerability Management Strategy. In support of this strategy, the Contractor shall execute vulnerability and compliance assessments using approved DoN tools (e.g., ACAS, SCAP, Evaluate STIG). Furthermore, the Contractor shall perform manual STIG and Security Requirements Guide (SRG) validations (via .ckl/.cklb checklists), generate appropriately formatted Security Center and eMASSter reports for seamless eMASS integration, and ensure all vulnerability scan results are accurately uploaded and maintained within the Vulnerability Remediation Asset Management (VRAM) database.
- Continuous Monitoring
    - The Contractor shall sustain robust System-Level Continuous Monitoring (SLCM) operations. Duties include conducting routine vulnerability scans, performing audit log analysis, driving vulnerability remediation/mitigation, and ensuring accurate, quarterly Plan of Action and Milestones (POA&M) updates.
- RMF On-Site Validation
    - The Contractor shall deliver targeted on-site validation and testing support to satisfy RMF Step 4 requirements, actively coordinating with system owners and independent validators to ensure seamless site assessments and accurate technical evidence collection.
- Configuration Management
    - The Contractor shall serve as a dedicated technical representative and/or Configuration Management (CM) Officer on the Configuration Control Board (CCB), providing authoritative security impact analyses and risk assessments for proposed FRCS baseline modifications.
- Incident Response Operations
    - The Contractor shall execute rapid incident response operations in direct support of the NAVFAC CIO. The Contractor shall serve as an operational member of the MAR Cyber Emergency Response Team (CERT), which mandates participation in designated on-call rotation schedules to guarantee continuous cyber defense coverage.
- Operational Coordination
    - The Contractor shall dynamically prioritize and coordinate technical support across all FRCS environments, regardless of project type or phase. The Contractor shall provide bi-weekly RMF status reports to the Information Systems Security Manager (ISSM). Furthermore, the Contractor shall create, maintain, and update FRCS RMF project status records within Maximo and/or eProjects on a strict bi-weekly cadence.

4.0 DELIVERABLES

Deliverable Name	Description	Associated Functional Area

Proof of Cyber Workforce Certification	Submission of valid, active certification credentials (e.g., Security+, CCSP, CISSP) required for DoDM 8140.03 Work Role 461 compliance prior to or during onboarding.	Personnel Qualifications / Onboarding
Monthly Invoices & Timesheets	Accurate monthly invoices matching contractor timesheets strictly submitted by the 15th of the month.	Contract Administration
Memorandum for Record (MFR) for Baseline Changes	MFRs documenting any system baseline changes in accordance with the latest NAVFAC Echelon II RMF Business Rules.	ATO Attainment & Maintenance
RMF Artifacts & eMASS Packages	Complete, verified, and quality-checked RMF artifacts for Steps 1 through 6, properly formatted and uploaded to eMASS.	RMF Lifecycle Execution
System Security Policies & SOPs	Drafted, reviewed, and finalized policy documents, standard operating procedures, and implementation plans mapped to NIST SP 800-53 control families.	Policy & Procedure Development
Vulnerability Management Strategy Document	A comprehensive strategy detailing the approach for identifying, tracking, and mitigating vulnerabilities across the FRCS environment.	Vulnerability Management & Compliance Assessments
Raw Vulnerability Scan Reports & VRAM Uploads	Output results from approved DoN vulnerability scanners (e.g., ACAS/Nessus) for all FRCS assets, including confirmation of VRAM database upload.	Vulnerability Management & Compliance Assessments
STIG & SCAP Compliance Reports	Automated scan results utilizing SCAP tools and/or Evaluate STIG.	Vulnerability Management & Compliance Assessments
Manual STIG & SRG Checklists	Completed .ckl or .cklb checklist files for required manual STIG and Security Requirements Guide (SRG) checks.	Vulnerability Management & Compliance Assessments
Security Center & eMASSter Reports	Generated reports from Security Center and eMASSter prepared	Vulnerability Management & Compliance Assessments

	and formatted for eMASS upload.	
Quarterly POA&M Updates	Updated Plan of Action and Milestones (POA&M) detailing vulnerability remediation, mitigation statuses, and continuous monitoring findings.	Continuous Monitoring (SLCM)
Audit Review Logs & SLCM Reports	Documentation of routine security control reviews, log analyses, and continuous monitoring activities.	Continuous Monitoring (SLCM)
On-Site Validation Support Documentation	Technical evidence, test results, and trip reports generated during RMF Step 4 on-site validation activities.	RMF On-Site Validation
Annual Security Review Packages	Documentation and security artifacts required to facilitate annual security reviews and maintain existing ATOs.	ATO Attainment & Maintenance
Incident Response (IR) Reports	After-action reports and operational logs detailing incident response activities, remediation steps, and CERT operations.	Incident Response Operations
Configuration Management (CM) Technical Inputs	Technical briefs, risk assessments, and recommendations presented at the Configuration Control Board (CCB).	Configuration Management
Bi-Weekly RMF Status & Database Updates	Status reports delivered to the ISSM detailing RMF progress, accompanied by confirmation of bi-weekly updates made to Maximo and/or eProjects records.	Operational Coordination & Reporting
Monthly Status Report (MSR)	Summary of all FRCS project support, task coordination based on CIO priorities, continuous monitoring activities, and upcoming ATO milestones.	Operational Coordination & Reporting

5.0 CERTIFICATIONS, LICENSE, PHYSICAL REQUIREMENTS OR OTHER EXPERTISE REQUIRED

The Contractor shall ensure that all personnel performing under this task order meet the baseline qualification requirements established by the Department of Defense (DoD) and Department of the Navy (DON) for their assigned Cyberspace Workforce (CWF) role. The specific work role and proficiency level required for this position are defined below:

In accordance with DoDM 8140.03, the personnel providing IT support under this contract must meet foundational qualification requirements for:

Work Role Code (WRC): 461
Work Role Title: Systems Security Analyst
Required Proficiency Level: Intermediate

To satisfy the Foundational Qualification requirement of DoDM 8140.03 for WRC 411, contractor personnel must possess and maintain at least one (1) of the approved commercial certifications prior to onboarding:

Proficiency Level	Certifications
Intermediate	CCSP, Cloud+, GICSP, GISF, GSEC, Security+
Advanced	RCCE Level 1, CISSO, CISSP-ISSEP, CySA+, FITSP-O, GCLD, GCSA, GSNA

Certifications aligned to higher proficiency levels automatically qualify for lower proficiency levels. The Contractor is responsible for ensuring certifications remain active and in good standing for the life of the contract.

The Contractor shall ensure that personnel maintain their certification status and complete a minimum of 20 hours annually of Continuous Professional Development (CPD), or the minimum hours required to maintain their commercial certification, whichever is greater. Proof of certification and CPD maintenance must be made available to the Contracting Officer's Representative (COR) upon request.

The contractor must:

- Be a United States citizen.
- Have an active Tier 5 (T5) security clearance or must obtain a T5 clearance prior to onboarding/hiring.
- Have a recommended minimum of 5 years of RMF experience and 1 year of specialized experience working on Facility-Related Control Systems (FRCS) performing Risk Management Framework (RMF) and cybersecurity engineering tasks.
- Have demonstrated the ability to operate independently with minimal government supervision.
- Have the ability to communicate in English fluently and effectively in oral and writing.
- Have demonstrated the ability to write comprehensive technical reports, security policies, and procedures, and communicate effectively with other governmental professionals, system owners, and the Information Systems Security Manager (ISSM).

- Be capable of the physical exertion required to perform the necessary services such as long periods of standing; walking over rough, uneven or rocky surfaces; recurring bending, crouching, stooping, and reaching; climbing upon ladders; lifting and moving IT equipment (up to 25 lbs); and other physical activity common to the performance of such duties and have sufficient vision to identify safety concerns.
- Be fully qualified in accordance with DoDM 8140.03 for Cyber Workforce Work Role 461 (Systems Security Analyst) at the intermediate or advanced proficiency level prior to onboarding.

6.0 TASK ORDER PERIOD OF PERFORMANCE

The period of performance will be specified in the task order.

7.0 PLACE OF PERFORMANCE

Naval Facilities Engineering Systems Command, Marianas

- Building 3190, Naval Base Guam (NBG), Santa Rita, Guam 96915
- Occasionally other FRCS building sites on the following installations:
    - Naval Base Guam (NBG)
    - Marine Corps Base Camp Blaz Guam (MCBCB)
    - Andersen Air Force Base Guam (AAFB)

Note: Local travel between the primary work site (Naval Base Guam) and secondary sites (Marine Corp Base Camp Blaz, Andersen AFB) is required. The contractor shall utilize their own Privately Owned Vehicle (POV) or company vehicle for local travel. Local mileage and commuting expenses are considered a cost of doing business and are not separately reimbursable by the Government.

8.0 OPERATIONAL HOURS

Work will be performed up to 40 hours per week during normal business hours, Monday-Friday, excluding Federal holidays. Work under this contract shall be in person, on or near the place of performance. Remote teleworking will not be allowed on this contract. Situational/Emergency teleworking may be allowed on a case-by-case basis and must be approved in advance by the Contracting Officer's Representative (COR). Should any part of the service be done remotely, the Contractor shall perform their duties during the normal working hours of the assigned project(s) time zone.

9.0 OVERTIME

Overtime is not authorized under this contract/task order. All work must be performed within the standard 40-hour work week during normal business hours. Due to the "Emergency Essential" nature of this role and the requirement to participate in the MAR Cyber Emergency Response Team (CERT) on-call rotation, the contractor may be required to respond to incidents outside of normal business hours. To offset these additional hours and ensure the total hours worked do not exceed 40 hours in a standard

work week, the contractor shall flex their schedule within the same work week. All after-hours incident response work and subsequent flex-schedule adjustments must be coordinated with the Contracting Officer's Representative (COR).

10.0 SAFETY ISSUES

The work described herein is primarily performed in an office setting. Some walking and moving of equipment will be required throughout the workplace facilities and at work sites. The office work environment involves everyday risks or discomforts that require normal safety precautions typical of such places as conference rooms, FRCS rooms/locations, server rooms, or office spaces.

11.0 GOVERNMENT-FURNISHED EQUIPMENT, BADGE, KEYS AND/OR FACILITIES PROVIDED

The Government will provide contractor personnel with an office environment typically provided to Government personnel that includes workstations, telephones and computers with access to the Internet and local area network (LAN). The Government will provide the Contractor with a building access badge that clearly identifies him/her as a Contractor employee. The Contractor shall ensure that such badge is visible on the Contractor employee at all times during the performance of the task order, including at off-base meetings. The Contractor will also ensure that Contractor employees do not present himself/herself as a Government employee. The Contractor shall ensure that all Contractor employee email correspondences, at a minimum, include the company name in the signature block.

12.0 SECURITY CLEARANCE/POLICE CHECK/DRIVING RECORD CHECK

Work under this task order is CONTROLLED UNCLASSIFIED INFORMATION (CUI). The contractor shall comply with all applicable Department of Defense (DoD) security regulations and procedures during the performance of this task order. The contractor shall not disclose and must safeguard procurement sensitive information, computer systems and data, privacy act data, and Government personnel work products that are obtained or generated in the performance of this task order. If necessary, the contractor will be required to provide clearances for personnel requiring access to Government computers and workstations.

Specifically, Information Systems Security Engineer (ISSE) will be required to have a Tier 5 (T5) clearance. T5 clearances are required to avoid inadvertent disclosure of sensitive or classified information to persons without the proper clearance, especially given the elevated network access often required for FRCS support.

Unclassified deliverables will sometimes be part of government responses to classified taskers. Individually, and separate from other pieces of information, contractor deliverables will be unclassified. However, continued exposure to individual pieces of unclassified information can result in the deduction and compromise of classified information. Information Assurance best management practices dictate that the contractor should have the required clearances.

13.0 REIMBURSABLE EXPENSES (TRAVEL)

Travel is not authorized under this contract/task order. All duties shall be performed at the designated place of performance, and the Government will not reimburse any travel-related expenses.

14.0 NON-PERSONAL SERVICE STATEMENT

Contractor employees performing services under this order will be controlled, directed and always supervised by management personnel of the contractor. The contractor's management shall ensure that employees properly comply with the performance standards outlined in the Performance Assessment Plan (PAP).

Contractor employees will perform independently without the supervision of any Government official. Actions of contractor employees may not be interpreted or implemented in any manner that results in any contractor employee creating or modifying Federal policy, obligating the appropriated funds of the U.S. Government, overseeing the work of Federal employees, providing direct personal services to any Federal employee or otherwise violating the prohibitions set forth in Parts 7.5 and 37.1 of the Federal Acquisition Regulation (FAR). The Government will control access to the facility and will perform the inspection and acceptance of the completed work.

15.0 CONTRACTING OFFICER REPRESENTATIVE (COR)

The Contracting Officer Representative shall provide general instructions on limitations and deadlines and is responsible for administration of the task order in compliance with the contract to include inspection and acceptance of deliverables.

16.0 PERFORMANCE ASSESSMENT PLAN (PAP)

Deliverable/Service	Performance Standard	Acceptable Quality Level (AQL)	Method Used/Frequency
Proof of Cyber Workforce Certification	Contractor provides valid proof of required certification (e.g., Security+, CCSP, CISSP) for DoDM 8140.03 Work Role 461 compliance during onboarding.	100% compliance. Personnel cannot onboard or bill to the contract without verified credentials.	100% Inspection / Prior to Onboarding
Monthly Invoicing	Invoices are submitted strictly by the 15th of the month, match contractor timesheets perfectly, and contain	100% accuracy and on-time submission by the 15th of the month.	100% Inspection / Monthly

	zero mathematical or billing errors.		
RMF Lifecycle Execution	All required RMF artifacts for Steps 1-6 are complete, compliant, accurately formatted, and successfully uploaded to eMASS.	95% of artifacts are submitted correctly on the first attempt without requiring rework due to contractor error.	100% Inspection / Per submission
ATO Attainment & Maintenance	Annual Security Reviews are facilitated on schedule. MFRs for baseline changes are drafted and submitted in accordance with NAVFAC business rules.	100% of Annual Reviews completed prior to the ATO expiration date. 95% of MFRs are submitted within 10 business days of a CCB-approved change.	Periodic Surveillance / Annually & As Required
Policy & Procedure Development	System Security Policies & SOPs are developed and maintained to align with NIST SP 800-53 controls and all relevant DoN/NAVFAC directives.	95% of developed policies and procedures are free from substantive errors and accurately reflect the operational environment and required controls.	Random Sampling / Quarterly
Vulnerability & Compliance Assessments	Vulnerability scans are executed, and results are accurately uploaded to VRAM. STIG/SCAP checks and manual checklists are completed per requirements.	95% of all required scans and checklists are completed within the required timeframe. 98% of scan results are uploaded to VRAM without error.	Periodic Surveillance / Monthly
Quarterly POA&M Updates	Plan of Action and Milestones (POA&M) documents are updated with the status of all open vulnerabilities, including remediation and mitigation progress.	95% of POA&M updates are delivered by the 5th business day of each quarter with all required fields accurately populated.	100% Inspection / Quarterly
Incident Response Operations	Contractor participates in on-call rotation and responds to	100% compliance with on-call rotation schedule. 100% of	Customer Complaint & 100% Inspection / As Required

	cybersecurity incidents in accordance with CERT procedures, providing after-action IR Reports.	critical incidents are responded to within the timeframe defined by the MAR CERT. IR Reports are submitted within 5 business days of incident closure.	
Configuration Management (CM) Technical Inputs	Contractor provides authoritative security impact analyses and risk assessments for proposed changes during CCB meetings.	95% of technical inputs are clear, accurate, and provide a sufficient basis for the CCB to make a risk-informed decision.	Periodic Surveillance / Per CCB Meeting
Bi-Weekly RMF Status & Database Updates	RMF status is reported to the ISSM, and corresponding Maximo/eProjects records are created and updated on schedule.	95% of reports are delivered on time. 98% of Maximo/eProjects records are updated accurately and on schedule.	100% Inspection / Bi-Weekly
Monthly Status Report (MSR)	A comprehensive MSR is delivered, summarizing all project support, CIO priority tasking, and monitoring activities.	MSRs are 95% complete and accurate and submitted by the 5th business day of the following month.	100% Inspection / Monthly